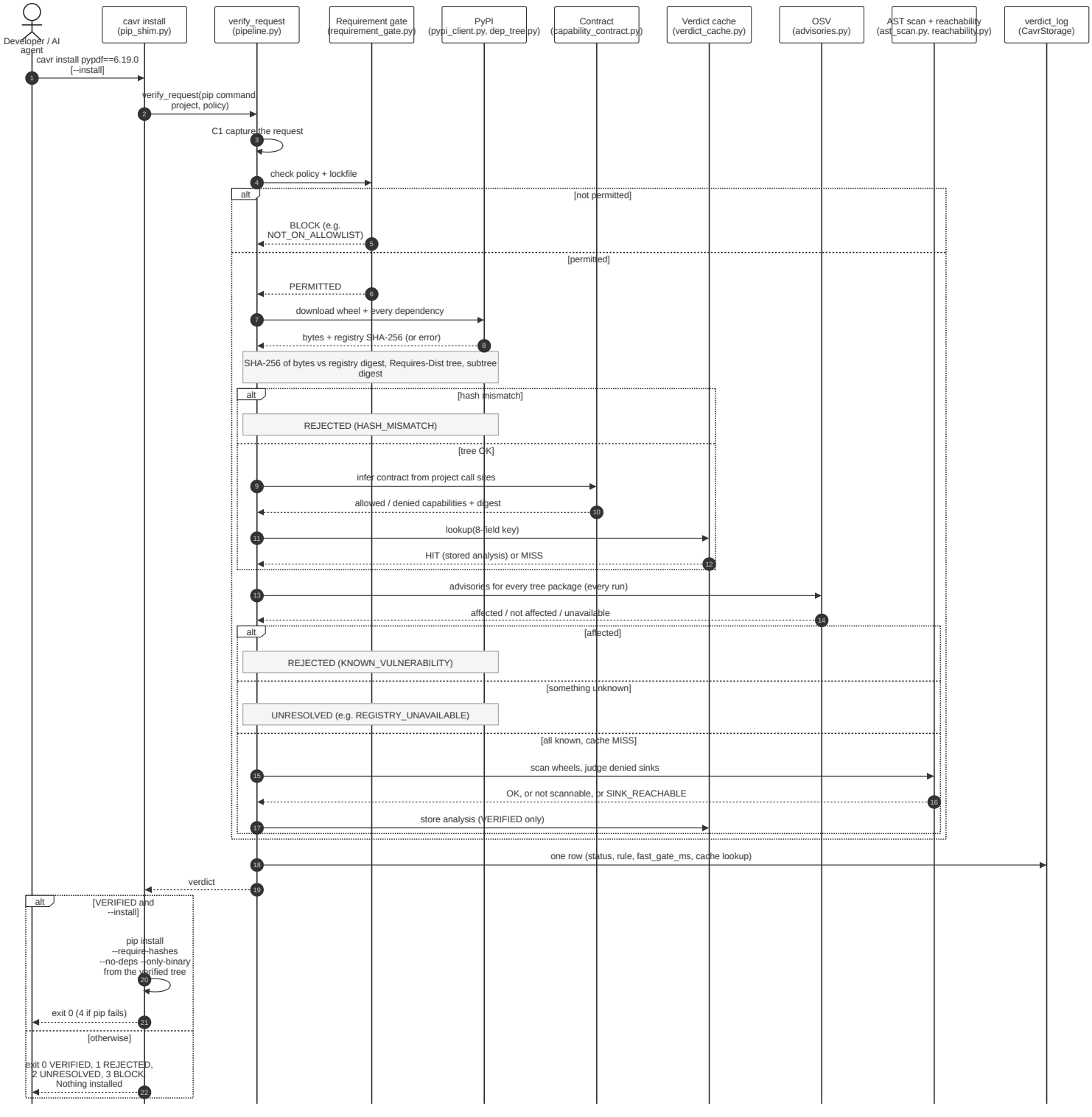

Developer / AI agent
cavr install (pip_shim.py)
verify_request (pipeline.py)
Requirement gate (requirement_gate.py)
PyPI (pypi_client.py, dep_tree.py)
Contract (capability_contract.py)
Verdict cache (verdict_cache.py)
OSV (advisories.py)
AST scan + reachability (ast_scan.py, reachability.py)
verdict_log (CavrStorage)
cavr install pypdf==6.19.0 [--install]
verify_request(pip command project, policy)
C1 capture the request
check policy + lockfile
alt
[not permitted]
BLOCK (e.g. NOT_ON_ALLOWLIST)
[permitted]
PERMITTED
download wheel + every dependency
bytes + registry SHA-256 (or error)
SHA-256 of bytes vs registry digest, Requires-Dist tree, subtree digest
alt
[hash mismatch]
REJECTED (HASH_MISMATCH)
[tree OK]
infer contract from project call sites
allowed / denied capabilities + digest
lookup(8-field key)
HIT (stored analysis) or MISS
advisories for every tree package (every run)
affected / not affected / unavailable
alt
[affected]
REJECTED (KNOWN_VULNERABILITY)
[something unknown]
UNRESOLVED (e.g. REGISTRY_UNAVAILABLE)
[all known, cache MISS]
scan wheels, judge denied sinks
OK, or not scannable, or SINK_REACHABLE
store analysis (VERIFIED only)
one row (status, rule, fast_gate_ms, cache lookup)
verdict
alt
[VERIFIED and --install]
pip install --require-hashes --no-deps --only-binary from the verified tree
exit 0 (4 if pip fails)
[otherwise]
exit 0 VERIFIED, 1 REJECTED, 2 UNRESOLVED, 3 BLOCK
Nothing installed